Auditoria de segurança e paridade dos bancos MultEduc

Data da coleta: 08/11/2026 (UTC)

Projetos: REL_AEE produção 2026 (hxmw...) — somente leitura; MultEduc ENSAIO 2027 (dvcshnudtzzjjklyejwf) — testes e correção limitados ao escopo autorizado.

Estado: parecer técnico preliminar; nenhuma migração, publicação, deploy ou correção foi aplicada em produção.

Resumo executivo

1. A view public.AlunoPermitido do ENSAIO permitia leitura de aluno de outra escola por UUID para admins; a tabela Aluno diretamente negava a mesma leitura.

2. Corrigido no ENSAIO com security_invoker=true, preservando security_barrier; advisor deixou de sinalizar security_definer_view.

3. A migration está em supabase/migrations/20261108131212_fix_alunopermitido_security_invoker.sql e corresponde ao timestamp 20261108131212 registrado no Supabase; o nome anterior (131143) foi corrigido na branch.

4. O teste HTTP antes da correção confirmou vazamento; a repetição autenticada depois não foi possível nesta sessão. Isolamento ainda não pode ser declarado provado.

5. Dados fictícios removidos do ENSAIO: contagem final zero para escola, turmas, alunos, usuários e sessões dos IDs sintéticos.

6. npx tsc --noEmit e npm run build passaram; isso não substitui a regressão funcional completa.

7. Paridade das migrações incompleta; checkout local sem histórico Git e com apenas parte dos arquivos impede fechar matriz de drift.

8. A Edge Function de ativação não exige autenticação própria nem implementa limitação de tentativas/envios visível; teste sem segredo retornou 404 para e-mail .invalid, indicando enumeração.

9. REL_AEE não teve escrita. Confirmação do ambiente publicado, backups/PITR, auditoria completa de funções e regressão integral permanecem pendentes.

10. Sem base para aplicar correções em produção. Não houve merge ou publicação.

Escopo, método e classificação

CONFERIDO significa observação direta em fonte, consulta SQL, advisor, teste controlado ou build. ESTIMATIVA identifica inferência sem fonte decisiva. Não foram consultados nem incluídos dados pessoais de alunos. Segredos, tokens, hashes e chaves não são reproduzidos.

Consultas foram feitas nos dois projetos Supabase; no REL_AEE somente leitura. O teste de isolamento usou escola, alunos, turmas e contas sintéticas no ENSAIO, com sessão app através do PostgREST antes da correção. O teste reproduziu o acesso cruzado somente pela view. A limpeza posterior foi limitada aos IDs fictícios e confirmou zero registros restantes.

Achados

ID	Parte	Severidade	Estado	Evidência	Correção proposta / risco
SEC-01	D	Crítica	CONFERIDO	Dois admins sintéticos de escolas A/B leram o UUID do aluno oposto via AlunoPermitido; consulta direta em Aluno retornou zero.	security_invoker=true no ENSAIO; risco: view exige grants/RLS corretos nas tabelas base. Prova HTTP pós-fix pendente.

SEC-02	A	Alta	CONFERIDO	Histórico: 95 migrations REL_AEE e 38 ENSAIO; comparação com checkout parcial mostra divergência. Multiescola aparece aplicada diretamente no banco e não na lista de migrations aplicadas.	Conciliar migrations reproduzíveis; risco de execução duplicada ou fora de ordem.
SEC-03	A1	Alta	PENDENTE	frontend/src/api.ts tem fallback para hxmw..., mas variáveis de hosting podem substituí-lo. Render não tinha workspace selecionado.	Confirmar workspace e variáveis sem revelar valores.
SEC-04	B/C	Alta	CONFERIDO PARCIAL	195 SECURITY DEFINER no REL_AEE (174 públicas) e 216 no ENSAIO (194 públicas). Inventário completo de metadados em CSV anexo; advisors: 132 EXECUTE anon no REL_AEE; 134 anon e 31 authenticated no ENSAIO.	Sem REVOKE em massa: RPCs usam anon com token e helpers servem policies/views. Classificação e dez critérios por função, além do mapa de dependências, não concluídos.
SEC-05	D	Alta	CONFERIDO	Advisor ENSAIO: 12 tabelas RLS sem policy; grants anon/authenticated ausentes nas tabelas públicas/app examinadas.	Confirmar desenho RPC/Edge e default privileges; sem correção automática.
SEC-06	D	Média	CONFERIDO	Ambos os projetos têm default privileges para tabelas/funções; grants padrão amplos podem alcançar novos objetos.	Planejar revogações pontuais após mapear fluxos; mudança geral pode quebrar RPCs.
SEC-07	E	Média	CONFERIDO PARCIAL	7 dias: 2026 Usuario INSERT 1/UPDATE 7; UsuarioAtivacaoCodigo INSERT 3/UPDATE 2; UsuarioSessao INSERT 44/UPDATE 7/DELETE 43. 2027 Usuario UPDATE 61; UsuarioAtivacaoCodigo INSERT 8/UPDATE 3/DELETE 13; UsuarioSessao INSERT 10/UPDATE 4/DELETE 5. Logs 24h: zero aviso no REL_AEE, 133 no ENSAIO.	Origem por fluxo específico não conclusiva; não alterar login sem rastrear chamadas.

SEC-08	F	Alta	CONFERIDO PARCIAL	enviar-codigo-ativacao verify_jwt=false, valida formato e consulta com service key, mas sem autenticação própria/rate limit visível. POST sem segredo retornou 404 para endereço .invalid.	Exigir autenticação, limite por IP/destinatário e respostas uniformes; teste de regressão necessário.
SEC-09	F	Média	CONFERIDO PARCIAL	alerta-push verify_jwt=false, valida segredo vindo por RPC; sem segredo retornou 401. Comparação retorna cedo se comprimento difere. Cron usa Vault; comando não contém bearer literal.	Rever comparação e ACLs; sem alteração.
SEC-10	F	Baixa	CONFERIDO PARCIAL	Tabelas de envio Agenda e alerta de faltas têm chaves únicas e reservas usam ON CONFLICT/RETURNING.	Destino e retentativa não testados com dispositivo real.
SEC-11	H	Média	CONFERIDO	8 tabelas history/lx_* no REL_AEE pertencem ao LottoX; anon/authenticated sem privilégios CRUD nas verificações.	Não alterar. Recomenda-se projeto próprio; eventual RLS só após aprovação.
SEC-12	H3	Alta	PENDENTE	Ferramenta não expôs política do plano, PITR nem data do último backup.	Consultar painel autorizado; nenhuma restauração/alteração de plano.
SEC-13	G	Média	CONFERIDO PARCIAL	Varredura heurística do checkout atual: zero segredo de service_role, VAPID privada, token Telegram ou senha SMTP. Dois JWTs são chaves públicas anon. Checkout sem histórico Git; busca remota cobriu só a branch padrão.	Varredura integral de branches/histórico não concluída.

Inventário e paridade

O CSV `inventario_security_definer_2026-11-08.csv` contém 411 linhas de funções (195 no REL_AEE e 216 no ENSAIO), com schema, nome, argumentos, owner, search_path e EXECUTE de anon/authenticated. Não inclui valores secretos. A análise de autorização, uso do token, escola/turma, colunas sensíveis, mensagens de erro, auditoria e rate limit segue parcial e não é substituída pelo inventário.

Métrica	REL_AEE 2026	ENSAIO 2027
Migrações registradas	95	38

Tabelas base públicas	131	110
Tabelas públicas com RLS	123	110
Tabelas públicas sem RLS	8	0
Políticas públicas	35	222
Triggers públicos	73	170
Funções SECURITY DEFINER públicas	174	194
Jobs cron observados	agenda-push-cada-minuto	busca-ativa-alerta-push

Os bancos não têm paridade de schema. No REL_AEE foram observadas 8 tabelas públicas sem RLS; pertencem ao LottoX e anon/authenticated não têm grants nas verificações feitas. No ENSAIO, advisories indicam 12 objetos com RLS e sem políticas, incluindo app_private; grants ausentes evitam exposição pela API nas tabelas examinadas.

AlunoPermitido tinha security_barrier=true e não tinha security_invoker=true. Após correção, reloptions mostrou ambas as opções. O advisor do ENSAIO deixou de apontar security_definer_view.

Checklist A-H

- A — Parcial. Contagens/diferenças e advisors consultados nos dois bancos. Matriz integral de migrações e A1 (Render) não fechados.
- B — Parcial. Inventário completo de metadados e grants anexado em CSV (411 linhas, incluindo os dois projetos). Classificação 1/2/3, dez critérios por função e dependências procedurais incompletos; sem revogação em massa.
- C — Pendente. Alguns RPCs inspecionados; usuario_admin_listar negou HTTP sem token e com token inválido. Testes de ataque de todas as funções/perfis/escolas e dez critérios por função não concluídos.
- D — Parcial. View analisada e corrigida no ENSAIO; advisor estrutural limpo. Teste HTTP autenticado pós-fix e quatro perfis pendentes.
- E — Parcial. Contagens e logs aferidos; atribuição do aviso a cada caminho de login/ativação não fechada.
- F — Parcial. Edge Functions e cron/Vault examinados parcialmente. CORS integral, limites, logs e idempotência em destino real não concluídos.
- G — Parcial. Estado local e referências da branch padrão examinados; histórico de todas as branches indisponível.
- H — Parcial. Testes fictícios removidos e contagem zero. LottoX intacto. Backup/PITR e último backup não verificáveis.

Correção aplicada somente no ENSAIO

Migration SQL:

ALTER VIEW public."AlunoPermitido" SET (security_invoker = true);

Rollback:

ALTER VIEW public."AlunoPermitido" RESET (security_invoker);

A aplicação pelo Supabase registrou versão 20261108131212. O arquivo inicialmente criado com timestamp 20261108131143 foi renomeado na branch para coincidir com o registro. A migração não foi aplicada no REL_AEE.

Testes executados

- Antes do fix: teste PostgREST com dois admins sintéticos; cada um leu UUID do aluno oposto pela view; a tabela Aluno negou a leitura. Falha crítica confirmada.
- Depois do fix: opção da view e advisor confirmados. Repetição HTTP autenticada indisponível nesta execução; função auxiliar de sessão não pode ser chamada com papel anon por SQL. Resultado funcional pós-fix: NÃO VERIFICADO.
- Limpeza: dry-run encontrou escola 1, turmas 2, alunos 2, contas QA 2 e sessões 12; dependências diretas de alunos/turmas consultadas em zero. Exclusão transacional seguida de contagens zero para todos os itens sintéticos.
- Código: npx tsc --noEmit passou; npm run build passou com avisos Vite conhecidos sobre CJS, script legado e chunk grande.
- Regressão funcional completa: login, ativação, 2FA, abas por perfil, Busca Ativa, alerta de faltas, Entrada/Saída, importação 2027 e Histórico não executados como bateria completa.

SQLs propostos

1. supabase/migrations/20261108131212_fix_alunopermitido_security_invoker.sql — correção SECURITY INVOKER, aplicada apenas no ENSAIO; arquivo alinhado ao histórico 20261108131212.

2. Não foram produzidos SQLs de correção para outras funções/Edge Functions: inspeção e testes exigidos para recomendar mudança segura não foram concluídos. Evitam-se revogações genéricas que podem quebrar login, ativação ou RPCs.

Itens não concluídos

- Ref Supabase realmente usada pelo hosting Render: workspace não selecionado; ferramenta exige seleção explícita.
- Matriz integral de 95/38 migrations por nome/branch: checkout local sem histórico e com árvore parcial.
- Dez critérios para cada função alvo, testes de ataque completos e mapa de dependências.
- Regressão funcional e prova PostgREST autenticada depois de security_invoker.
- CORS/rate limiting completos, push em dispositivo real e revisão integral dos logs por dados pessoais.
- Backup/PITR e horário do último backup REL_AEE.
- Varredura de todas as branches e commits dos dois repositórios.
- Revisão cruzada DeepSeek/Claude; pareceres não foram inventados.

Parecer final

Pode ir para produção

Nenhuma correção pode ser aplicada no REL_AEE agora. O fix da view tem evidência da falha antes e evidência estrutural após no ENSAIO, mas faltam prova autenticada pós-fix, regressão funcional e revisão cruzada.

Precisa de decisão do Ricardo

- Confirmar o workspace Render para verificar variáveis ativas sem revelar valores.
- Confirmar acesso ao painel de backups/PITR do REL_AEE.
- Deliberar eventual separação do LottoX em projeto Supabase próprio.
- Aprovar desenho de qualquer correção que mude autenticação, ativação ou RPCs públicas após pacote de testes.

Bloqueado ou com risco

- Crítico: AlunoPermitido vazava entre escolas antes do fix. Não usar segunda escola com dados reais antes do teste autenticado pós-correção.
- Alto: ativação por código sem autenticação própria/rate limit visível e respostas que permitem enumeração.
- Alto: schema e migrations não reconciliados.
- Alto: hosting e backups não confirmados.
- Alto: inventário/testes de funções administrativas incompletos; sem base para REVOKE em massa.

O que levar à Mesa Virtual para revisão cruzada

1. Este parecer e as evidências anonimizadas do teste de acesso à view.

2. Migration security_invoker do ENSAIO, timestamp alinhado e teste HTTP pós-fix.

3. CSV completo de funções SECURITY DEFINER e, para fechar B/C, classificação e mapa de dependências/testes por função.

4. Inventário integral de migrations por banco e branch, separando drift de diferença de timestamp.

5. Relatório completo dos testes de ataque e regressão funcional.

6. Evidência Render e backup/PITR sem valores de secrets.

7. Parecer sobre autenticação, limitação de envio e respostas da Edge Function de ativação.